PlantProcess IQ -- Security and Data Protection

Document class	Security and Procurement Brief
Audience	Security, OT/automation, DBA, procurement
Product	PlantProcess IQ (PPIQ) -- SOU Industrial Software
Version	1.0 -- June 2026

This document is written for the security, automation, and database teams whose approval is required before a plant adopts new software. Each control below is a design property of the product.

1. Read-only is absolute

PlantProcess IQ never writes to, issues a command to, changes a setpoint on, or runs a schema-changing statement against any source or control system. Every outbound action is a message, an export, or a webhook. There is no write-back path of any kind. This is the single most important property of the product and it is non-negotiable.

2. OT-safe acquisition

Sources are reached through a customer-controlled edge collector that pushes data one way toward the core. The core never initiates a connection into the operational-technology network. A one-way data-diode topology is supported for environments that require physical guarantee of direction.

3. Source-load protection

Reads against a source are bounded: per-source row caps, statement timeouts, rate limits, and approved time windows apply. Historical backfill is throttled, checkpointed, and resumable, and is never executed as a single large query against a production source.

4. Identity, token, and session security

The access token is held in memory in the browser and is paired with an HttpOnly refresh cookie subject to rotation and revocation; tokens are never placed in browser local storage. Passwords are hashed with a modern memory-hard algorithm. Multi-factor authentication is available and can be enforced for privileged and administrative access.

5. Secrets handling

Source credentials live only in the collector's encrypted vault, are masked on read-back, and are never present in the browser or in application configuration. Signing keys are per-environment and are never hard-coded. Secrets such as enrollment material are stored encrypted at rest.

6. Tenant isolation

In the multi-tenant model, isolation is enforced by tenant identifier together with row-level security, governed by a single rule set; in the dedicated model, isolation is physical. A cross-tenant request returns an empty or forbidden result.

7. Per-endpoint authorization

Every endpoint, page, job, and tool checks both role and entitlement, resolved by a single backend authority so that a capability cannot be reached by calling the API directly. Development and diagnostic endpoints are not reachable in a production build; they are gated to non-production environments and that gate is enforced by an automated test.

8. AI data boundary

Analytical computation is performed by deterministic engines that run inside the tenant; plant data is not sent to an external model to be computed. Where a natural-language assistant is used, it explains existing findings with citations and operates against a self-hosted or zero-retention private endpoint that receives only the question and the scoped evidence. A per-tenant no-egress setting is available. The assistant cannot present a number that is not grounded in a resolvable piece of evidence.

9. Audit and encryption at rest

Sensitive actions are recorded in an append-only, immutable audit log. Data and secrets are encrypted at rest.

10. Deployment hardening

The database port is bound to the loopback interface and is not publicly exposed. The initial bootstrap administrator is replaced by a real administrative account before production use. Health and readiness endpoints and operational runbooks are provided.

Summary posture

PlantProcess IQ is built so that a plant's automation and security teams can approve it without a control-systems risk review or a data-egress concern. It reads, it isolates, it encrypts, it audits, and it never writes back. The product's value comes from understanding the data a plant already produces -- not from touching the systems that produce it.